

Recobro Security & Governance

Security and Governance Note

Build: Recobro. Deterministic subrogation and recovery screener.

This note records the security and governance controls applied to the reference implementation, the reasoning behind each, and its current status.

1. Human oversight and no autonomous action
Control: Every file leaves the workflow with status "pending human decision." The system never sends a notice to a third party, never initiates legal action, and never closes a file.
Rationale: The system must never decide to pursue, investigate, or close on its own, and never initiate any recovery action. The reinsurance flag only routes information to the reinsurance team; it never changes the recovery band or triggers any action by itself.
Status: Implemented.
2. PII masking, twice
Control: Personal data (names, emails, phone numbers, ID numbers) is masked via Amazon Bedrock Guardrails on the way into the extraction step, and again on the way out of the composition step.
Rationale: Masking on the way out serves as a second line of defence.
Status: Implemented and evaluated against six synthetic files, with zero leaks confirmed.
3. Least-privilege IAM
Control: The flow's execution role can invoke only the one EU model inference profile in use and the four named recobro-* Lambda functions, with nothing else in the account accessible. The masking Lambda role can call ApplyGuardrail only on this specific guardrail.
Rationale: The flow and its components should have access to only the permissions they need to do their job, meaning a compromise cannot reach unrelated resources.
Status: Implemented.
4. Deterministic legal-deadline logic and auditability
Control: Every deadline is computed in code from a versioned rule table stamped on every memo, never estimated by the model. Structured warnings (a corrected date, a missing field) are surfaced to the handler rather than silently resolved.
Rationale: This ensures nothing is hidden from the person making the final call. A defect that let a deadline start before the triggering event was found in live testing and fixed at the code level, with the correction logged as a visible warning in the memo for the handler to see.
Status: Implemented.
5. Data residency
Control: The system runs in the Frankfurt region (eu-central-1) using Claude Sonnet 4.5 on the EU geo inference profile.
Rationale: This keeps model processing within EU regions.
Status: Implemented.

6. Data handling

Control: All claim files, names, and figures used in this build are synthetic, not real claimant information.

Rationale: They were generated specifically to include personal data patterns for testing the masking safely.

Status: Implemented.

7. Deliberately out of scope for this reference implementation

The following are not implemented, by scope:

Rule validation: the rule table (deadlines and thresholds) is illustrative and not yet validated by legal.

Evaluation scale: the evaluation set is six files, not a full labelled production set.

System integration: there is no integration with a core claims system yet.